



Dinesh Anbumani



API SECURITY

ARCHITECTURE GUIDE





SECTION 1

API THREAT LANDSCAPE

TOP API THREATS (OWASP API SECURITY TOP 10)

THREAT

ARCHITECTURE FAILURE

Broken Object Level Authorization (BOLA)

Missing per-object access checks

Broken Authentication

Weak token design or validation

Broken Object Property Level Authorization

Over-exposed response fields

Unrestricted Resource Consumption

No rate limiting or quotas

Broken Function Level Authorization

Admin endpoints exposed to users

Unrestricted Access to Sensitive Business Flows

No bot/abuse detection

Server-Side Request Forgery (SSRF)

Unvalidated server-side URL calls

Security Misconfiguration

Default configs, verbose errors

Improper Inventory Management

Shadow APIs, undocumented endpoints

Unsafe Consumption of APIs

Trusting third-party API responses blindly





SECTION 2

API AUTHENTICATION ARCHITECTURE

AUTHENTICATION PATTERNS BY USE CASE

USE CASE

RECOMMENDED PATTERN

Public API (third-party developers)

OAuth 2.0 + API Key

Internal service-to-service

mTLS + short-lived JWT

User-facing mobile/web app

OAuth 2.0 (PKCE flow) + OIDC

Partner integrations

OAuth 2.0 Client Credentials

Legacy system integration

API Key + IP allowlist

TOKEN DESIGN STANDARDS:

- JWT signed with RS256 or ES256 (asymmetric)
- Access token lifetime: 15 minutes maximum
- Refresh token rotation enforced on every use
- Token claims scoped to minimum required permissions
- Token revocation list maintained in cache (Redis)

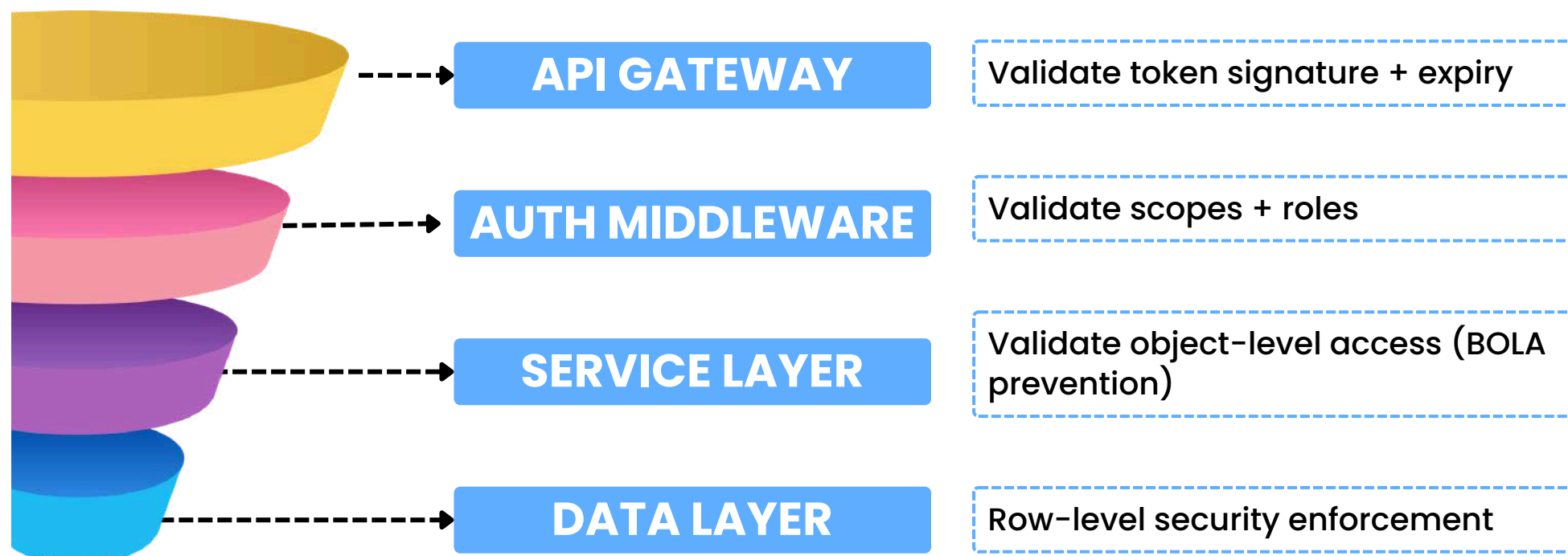




SECTION 3

API AUTHORIZATION ARCHITECTURE

AUTHORIZATION LAYERS



AUTHORIZATION MODELS BY API TYPE

API TYPE	AUTHORIZATION MODEL
RESOURCE APIS	RBAC + ABAC hybrid
ADMIN APIS	JIT access + strict RBAC
PARTNER APIS	Tenant-scoped tokens + ABAC
INTERNAL APIS	Service identity + scope-based

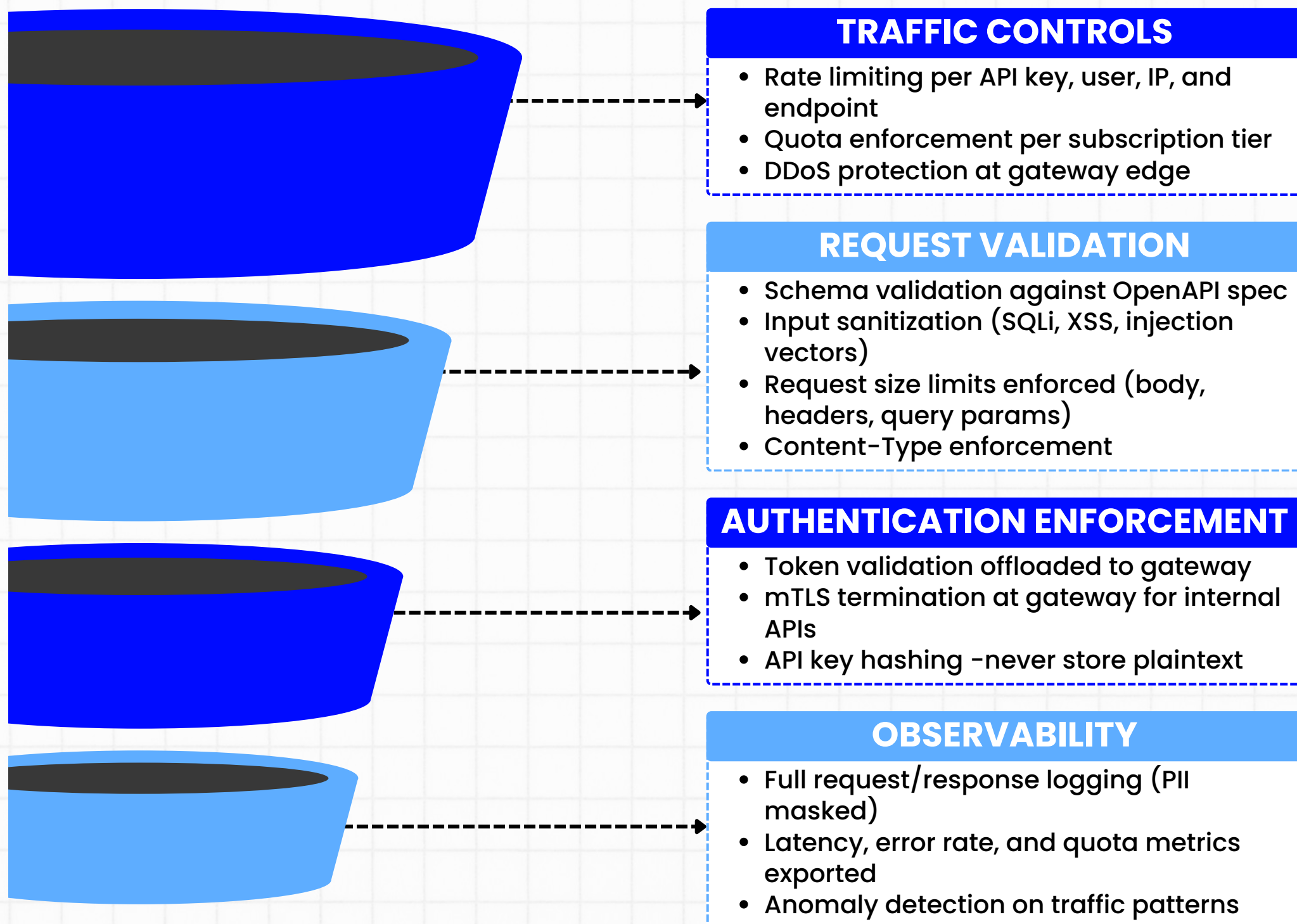




SECTION 4

API GATEWAY SECURITY ARCHITECTURE

GATEWAY CONTROL LAYERS





SECTION 5

SECURE API DESIGN PRINCIPLES



10 NON-NEGOTIABLE DESIGN RULES

- Never expose internal object IDs directly – use opaque tokens or UUIDs
- Return minimum required fields in every response
- Version all APIs – deprecate, never delete without notice
- Use nouns not verbs in resource paths
- Enforce HTTPS only – reject HTTP at gateway, not application
- Separate read and write scopes in OAuth token design
- Log all authorization failures with context
- Never return stack traces or internal errors to clients
- Validate all input server-side regardless of client validation
- Document every endpoint in OpenAPI spec before it ships





SECTION 6

API SECURITY TESTING CHECKLIST

PRE-PRODUCTION GATES

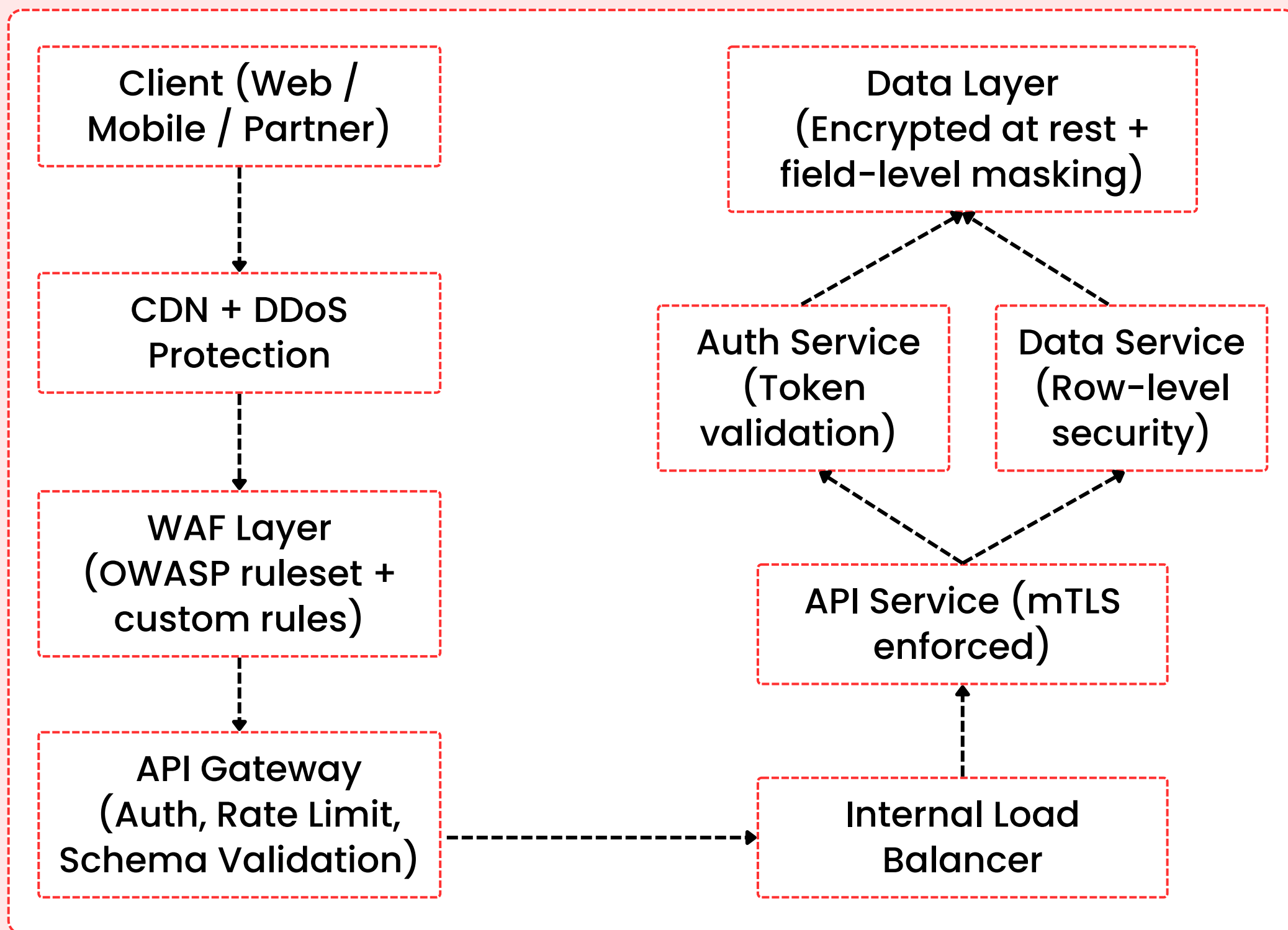
- OWASP API Top 10 scan completed
- Authentication bypass tests executed
- BOLA tests run across all resource endpoints
- Rate limiting validated under load
- Sensitive data exposure review on all response payloads
- SSRF test cases executed on all URL-accepting parameters
- Fuzzing run against input fields and headers
- Broken function level auth tested against admin endpoints
- OpenAPI spec validated – no undocumented endpoints in production
- Secrets scan on codebase – no API keys in source code





SECTION 7

API SECURITY ARCHITECTURE REFERENCE DIAGRAM



Want more content like this?



DINESH ANBUMANI

SOLUTION ARCHITECT

Tap that follow button, hit repost,
and stay in the loop !



Like



Comment



Share



Save



Repost